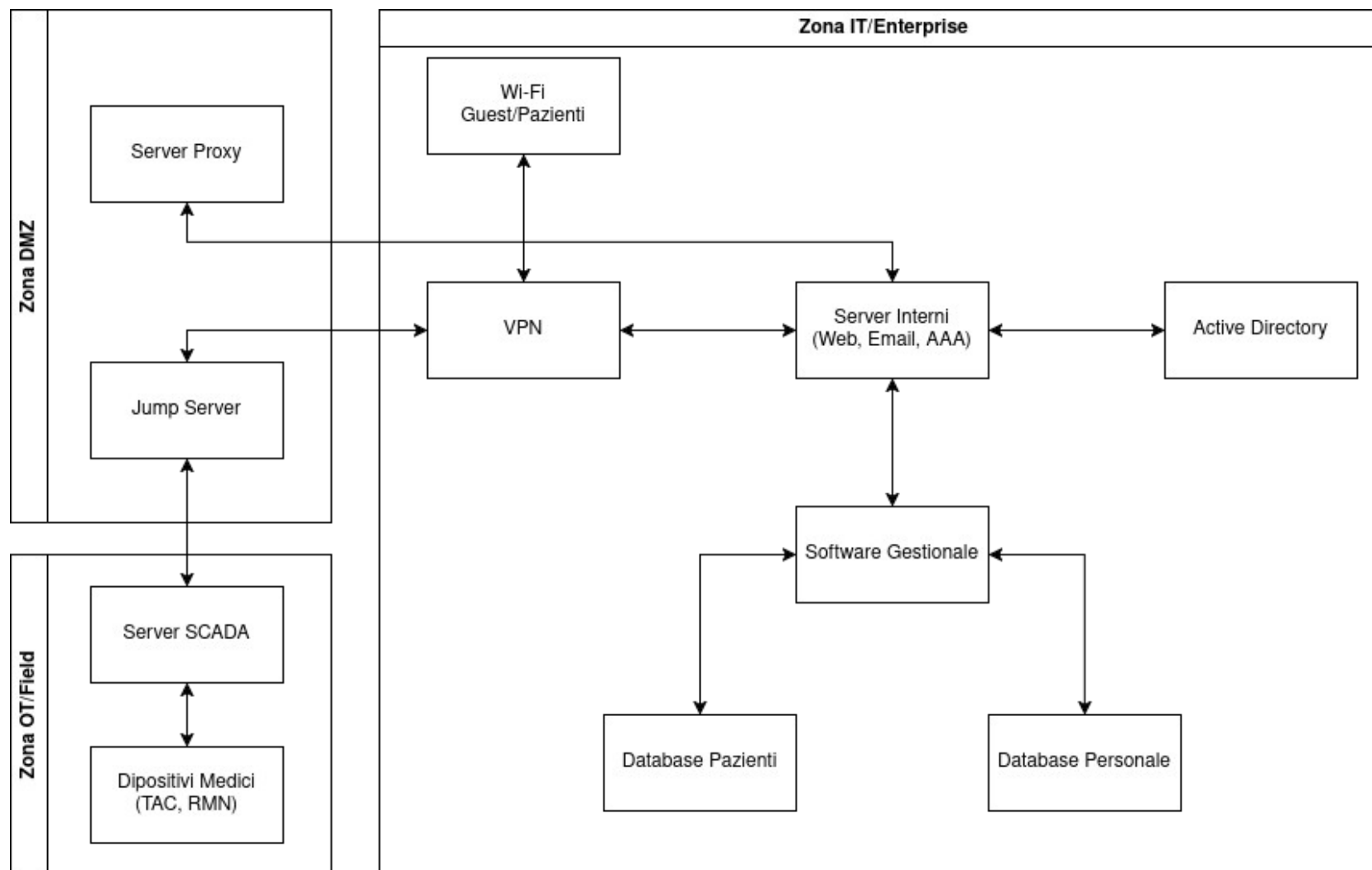


Threat Modeling Azienda Ospedaliera

Ionut Georgian Zbirciog, Francesco Cosciotti , Franco Salvucci

Grafo dell'Infrastruttura



Definizione Baseline

Relazione	Normale	Quando	Intensità Attese	Note
VPN to Jump Server	SI	Manutenzione	Bassa	Accesso remoto da parte dei sistemisti.
VPN to Server Interni	SI	Sempre	Alta	Accesso remoto da parte dei medici.
Server Interni to Gestionale	SI	Sempre	Alta	Accesso applicativi interni.
Gestionale to DB Pazienti	SI	Sempre	Alta	Backend applicativo.
Gestionale to DB Personale	SI	Sempre	Media	Backend applicativo.
Dispositivi Medici to SCADA	SI	Sempre	Alta	Monitoraggio dispositivi medici.
Jump Server to Scada	SI	Manutenzione	Media	Accesso da parte dei sistemisti.
Guest Wi-Fi to SCADA	NO	Mai	Nulla	Deviazione topologica.
Server Interni to DBs	NO	Mai	Nulla	Deviazione topologica.

Dataset Osservato

Time	Source	Destination	Protocol	Pkts	Status
8:30	Active Directory	Server Interni	LDAP	85	ok
8:45	Wi-Fi Guest	Portale Referti (Web)	HTTPS	110	ok
9:15	VPN	Server Interni	TLS	120	ok
9:20	Software Gestionale	DB Pazienti	SQL	450	ok
9:22	TAC (Field Zone)	Server SCADA	DICOM	800	ok
11:00	Wi-Fi Guest	Server SCADA	TCP	15	fail
12:15	VPN	Jump Server	RDP	300	ok
13:00	Jump Server	PCL-Radiologia	Proprietary	45	fail
14:10	Jump Server	192.168.5.10 (Unknown)	SSH	55	ok
15:20	Laptop-Amministrazione	Active Directory	Kerberos	5	retry
15:21	Laptop-Amministrazione	Active Directory	Kerberos	1	fail
16:30	VPN	Server Interni	TLS	12	retry
16:32	VPN	Server Interni	TLS	8	fail
22:10	Unknown-Host (DMZ)	Active Directory	SMB/RPC	400	ok
23:45	RMN (Field Zone)	Internet-Gateway	HTTP	15	fail
3:00	Software Gestionale	DB Pazienti	SQL	5000	ok
3:05	DB Pazienti	203.0.113.42 (External)	TCP/IP	1200	ok
4:15	RMN (Field Zone)	Server SCADA	HL7	0	fail

Valutazione Preliminare

Time	Source	Destination	Compatibile	Deviation	Causa
8:30	Active Directory	Server Interni	SI	NULL	Normale Comportamento
8:45	Wi-Fi Guest	Portale Referti (Web)	SI	NULL	Normale Comportamento
9:15	VPN	Server Interni	SI	NULL	Normale Comportamento
9:20	Software Gestionale	DB Pazienti	SI	NULL	Normale Comportamento
9:22	TAC (Field Zone)	Server SCADA	SI	NULL	Normale Comportamento
11:00	Wi-Fi Guest	Server SCADA	NO	FORTE	Attacco
12:15	VPN	Jump Server	SI	NULL	Manutenzione
13:00	Jump Server	PCL-Radiologia	SI	LIEVE	Fault
14:10	Jump Server	192.168.5.10 (Unknown)	NO	FORTE	Attacco
15:20	Laptop-Amministrazione	Active Directory	SI	BASSA	Unknown
15:21	Laptop-Amministrazione	Active Directory	SI	BASSA	Fault
16:30	VPN	Server Interni	SI	LIEVE	Unknown
16:32	VPN	Server Interni	SI	LIEVE	Fault
22:10	Unknown-Host (DMZ)	Active Directory	NO	ALTA	Attacco
23:45	RMN (Field Zone)	Internet-Gateway	NO	ALTA	Unknown
3:00	Software Gestionale	DB Pazienti	NO	ALTA	Unknown
3:05	DB Pazienti	203.0.113.42 (External)	NO	ALTA	Attacco
4:15	RMN (Field Zone)	Server SCADA	SI	BASSA	Fault

Valutazione Deviazioni

Time	Source	Destination	Score	Class.	Dato Utile
11:00	Wi-Fi Guest	Server SCADA	FORTE	Attacco	MAC address del dispositivo ospite e verifica immediata delle ACL del firewall.
13:00	Jump Server	PCL-Radiologia	LIEVE	Fault	Log applicativi del PLC per confermare il guasto di comunicazione.
14:10	Jump Server	192.168.5.10 (Unknown)	FORTE	Attacco	Identificazione dell'IP sconosciuto e verifica sessioni attive sul Jump Server.
15:20	Laptop-Amministrazione	Active Directory	BASSO	Unknown	Nessuno al momento (possibile errore di battitura password dell'utente)
15:21	Laptop-Amministrazione	Active Directory	BASSO	Fault	Ticket IT aperto dall'utente per reset credenziali bloccate.
16:30	VPN	Server Interni	LIEVE	Unknown	Indirizzo IP di origine per escludere un attacco di brute force geografico.
16:32	VPN	Server Interni	LIEVE	Fault	Log del server VPN (es. certificato scaduto o disconnessione di rete).
22:10	Unknown-Host (DMZ)	Active Directory	ALTA	Attacco	IP e MAC dell'host sconosciuto nella DMZ, e verifica log dell'IPS.
23:45	RMN (Field Zone)	Internet-Gateway	ALTA	Unknown	Analisi del payload HTTP (potrebbe essere un update non documentato o esfiltrazione)
3:00	Software Gestionale	DB Pazienti	ALTA	Unknown	Verifica task schedulati (es. backup massivo notturno) per escludere furto dati
3:05	DB Pazienti	203.0.113.42 (External)	ALTA	Attacco	Dati di intelligence sull'IP esterno e volume dei byte trasmessi (esfiltrazione).
4:15	RMN (Field Zone)	Server SCADA	BASSO	Fault	Log di stato della RMN per verificare guasti al sensore o fermo macchina notturno

Conclusioni

- Deviazione più grave:
È rappresentata dall'evento delle 03:05 DB Pazienti to 203.0.113.42.
- Deviazione più ambigua:
È rappresentata da eventi come 15:20 Laptop-Amm. to AD (retry).
- Deviazione che richiede una risposta tempestiva:
Sono eventi 03:05 DB Pazienti to 203.0.113.42
- Quando classificare un'evento come unknown:
La decisione "Unknown" non è da intendersi come un errore dell'analista, bensì come la classificazione più corretta quando si osserva un evento ambiguo.



TOR VERGATA
UNIVERSITÀ DEGLI STUDI DI ROMA